



Российский государственный университет нефти и газа (НИУ) имени И.М. Губкина
ФАКУЛЬТЕТ КОМПЛЕКСНОЙ БЕЗОПАСНОСТИ ТЭК

Федеральное государственное автономное образовательное
учреждение высшего образования «Российский государственный
университет нефти и газа (национальный исследовательский
университет) имени И.М. Губкина»

Факультет комплексной безопасности ТЭК



Разработка паттерна для обеспечения безопасности веб-приложений в нефтегазовом комплексе при угрозе атак в облачной инфраструктуре

Выполнил:
Студент группы КС-21-04
Лазорин Данил Сергеевич

Руководитель:
д.т.н., профессор
Корнеев Н.В.
кафедра КБИТ



Актуальность работы

Существующие решения в области безопасности веб-приложений реализуются в виде отдельных инструментов, механизмов на различных уровнях архитектуры системы.



Актуальность работы

Каждый компонент функционирует разрозненно, требует сложной настройки и не обеспечивает единого подхода к защите веб-приложений в облачной инфраструктуре.



Цель работы

Повышение уровня безопасности веб-приложений нефтегазового комплекса при угрозе атак в облачной инфраструктуре.



Цель работы

Инструментом достижения цели выступает разрабатываемый паттерн – типовое архитектурное решение, реализуемое в виде унифицированного микросервиса безопасности и объединяющее механизмы противодействия XSS- и CSRF-атакам, поведенческий анализ действий пользователя и журналирование событий безопасности.



Задачи

1. Провести обзор научных публикаций по теме.
2. Провести теоретическое обоснование безопасности веб-приложений в нефтегазовом комплексе при угрозе атак в облачной инфраструктуре.
3. Классифицировать веб-приложения в нефтегазовом комплексе и определить актуальную группу веб-ресурсов для исследования.



Задачи

4. Составить модель угроз актуальной группы веб-ресурсов.
5. Рассмотреть механизмы защиты при угрозах атак в облачной инфраструктуре для выбранной группы веб-ресурсов.
6. Разработать паттерн для обеспечения безопасности для выбранной группы веб-ресурсов, который будет включать себя архитектуру подсистем регистрации, авторизации, отслеживания событий, механизмов защиты.



Задачи

7. Проработать способы интеграции разработанного решения с технологическим оборудованием.
8. Разработать микросервис паттерна для обеспечения безопасности с помощью технологии контейнеризации.
9. Провести тестирование и мониторинг разработанного решения на кластере.



Объект и предмет исследования

Объектом исследования являются веб-приложения нефтегазового комплекса.

Предметом исследования являются методы и механизмы обеспечения безопасности веб-приложений нефтегазового комплекса при угрозах атак в облачной инфраструктуре.



Выдвинутые гипотезы

Гипотеза 1. Существующие средства защиты веб-приложений в облачной инфраструктуре нефтегазового комплекса реализуются точечно и обособленно, что снижает эффективность противодействия XSS- и CSRF-атакам. Гипотеза



Выдвинутые гипотезы

Гипотеза 2. Наиболее актуальными угрозами для веб-приложений нефтегазового комплекса в облачной инфраструктуре являются XSS и CSRF.



Выдвинутые гипотезы

Гипотеза 3. В отечественной практике отсутствует единая архитектура (паттерн) обеспечения безопасности веб-приложений нефтегазового комплекса, объединяющая подсистемы регистрации, авторизации, мониторинга событий и защиты от XSS/CSRF.

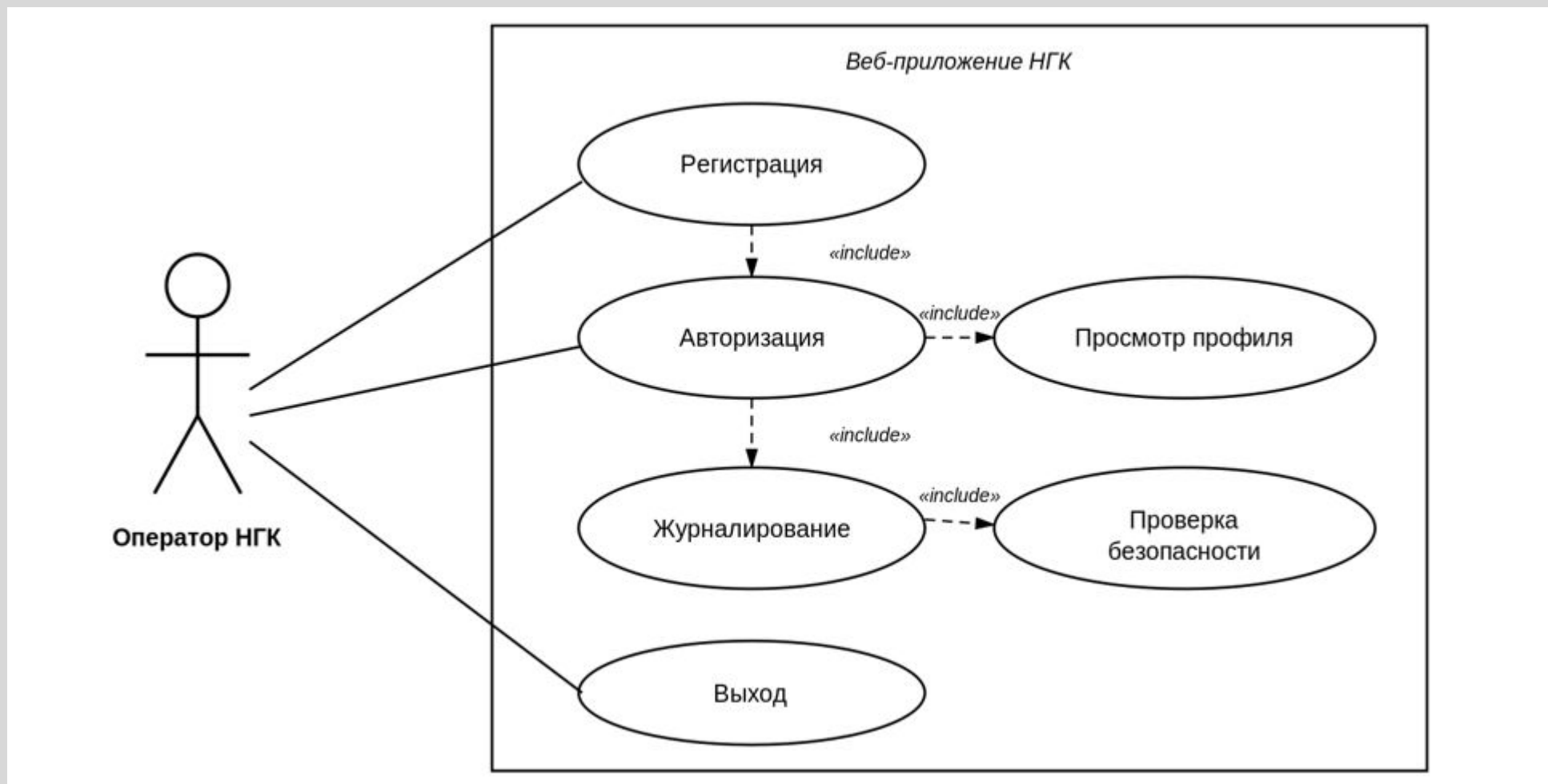


Рисунок 1 – Use-case диаграмма веб-приложения (составлено автором)



Идентификатор	Актор	Краткая характеристика
А-1	Незарегистрированный пользователь	Внешний субъект с доступом только к открытой части — страницам регистрации и авторизации
А-2	Зарегистрированный пользователь (оператор)	Сотрудник предприятия НГК, прошедший регистрацию; имеет доступ к системе управления (профиль, статистика, журнал)
А-3	Администратор безопасности	Сотрудник службы ИБ с расширенными правами; работает с панелью инцидентов, журналом событий, фильтрацией
А-4	Внешний нарушитель	Лицо без легитимных учётных данных, осуществляющее попытки XSS-, CSRF-атак и подбора паролей
А-5	Автоматизированный сценарий (бот)	Программное средство, имитирующее действия пользователя для массовых атак, перебора, сканирования

Таблица 1. Акторы веб-приложения



Российский государственный университет нефти и газа (НИУ) имени И.М. Губкина
ФАКУЛЬТЕТ КОМПЛЕКСНОЙ БЕЗОПАСНОСТИ ТЭК

ИД БДУ	Наименование угрозы	К	Ц	Д	Источник угрозы	Объект воздействия
УБИ.041	Межсайтовый скриптинг (XSS)	+	+	—	A-4, A-5	Сессионные данные, ПДн, DOM-дерево
УБИ.042	Межсайтовая подделка запроса (CSRF)	—	+	—	A-4	Бизнес-операции активной сессии
УБИ.033	Использование слабостей кодирования входных данных	+	+	+	A-4	СУБД, обрабатываемые данные
УБИ.017	Доступ/перехват/изменение HTTP cookies	+	+	—	A-4	Сессионные cookies
УБИ.008	Повторное использование аутентификационной информации	+	±	—	A-4, A-5	Учётные данные
УБИ.030	Использование данных идентификации по умолчанию	+	+	+	A-4	Учётные записи
УБИ.031	Использование механизмов авторизации для повышения привилегий	+	+	±	A-4	Права доступа
УБИ.006	Внедрение кода или данных	+	+	+	A-4	Сервер, БД
УБИ.014	Длительное удержание вычислительных ресурсов	—	—	+	A-4, A-5	Доступность сервиса
УБИ.016	Доступ к локальным файлам сервера через URL	+	—	—	A-4	Файловая система сервера

Таблица 2. Актуальные угрозы безопасности веб-ресурсов НГК и их влияние на триаду КЦД



№	Формулировка
FR-1	Веб-приложение должно предоставлять стартовую страницу с формой авторизации и переходом к регистрации
FR-2	Веб-приложение должно обеспечивать регистрацию пользователя с сохранением учётных данных в БД
FR-3	Веб-приложение должно обеспечивать идентификацию, аутентификацию и авторизацию пользователя
FR-4	После аутентификации веб-приложение должно перенаправлять пользователя на страницу профиля с его данными
FR-5	Веб-приложение должно журналировать действия пользователя на каждом этапе
FR-6	Веб-приложение должно валидировать и фильтровать данные средствами сервиса безопасности до передачи в БД
FR-7	Веб-приложение должно формировать и проверять токены синхронизации для запросов, изменяющих состояние (защита от CSRF)

Таблица 3. Функциональные требования



ID	Формулировка
BR-1	Пароль хранится только в виде хеша bcrypt (cost $\geq$ 10); хранение в открытом виде запрещено
BR-2	Поле логина/e-mail уникально в пределах системы
BR-3	Сессионный идентификатор ротируется после успешной аутентификации
BR-4	Журнал событий не редактируется через интерфейс — только запись и просмотр
BR-5	Резервная копия журнала создаётся по достижении порога записей; хранятся последние 10 копий
BR-6	Запрос считается аномальным при $\text{time_on_page} < 3$ с, либо $\text{mouse_movements} < 3$, либо $\text{sudden_jumps} > 20$
BR-7	После 5 неуспешных попыток входа за 15 минут учётная запись временно блокируется
BR-8	Cookies устанавливаются с атрибутами HttpOnly, Secure, SameSite=Strict

Таблица 4. Бизнес правила



Российский государственный университет нефти и газа (НИУ) имени И.М. Губкина
ФАКУЛЬТЕТ КОМПЛЕКСНОЙ БЕЗОПАСНОСТИ ТЭК

ID	Условие	Действие системы	Сообщение	Запись в журнал
ERR-1	Невалидный формат логина/e-mail	HTTP 400, форма с пометкой	«Некорректный формат данных»	VALIDATION_ERROR
ERR-2	Регистрация на занятый логин	HTTP 409	«Пользователь уже зарегистрирован»	REG_DUPLICATE
ERR-3	Невалидный CSRF-токен	HTTP 403	«Запрос отклонён системой безопасности»	CSRF_VIOLATION
ERR-4	Обнаружен XSS-паттерн	HTTP 400, поле очищается	«Обнаружено недопустимое содержимое»	XSS_ATTEMPT
ERR-5	Аномальное поведение	HTTP 429, сессия завершается	«Запрос отклонён системой защиты»	BEHAVIOR_ANOMALY
ERR-6	Превышение числа попыток входа	Временная блокировка	«Учётная запись временно заблокирована»	AUTH_LOCKED
ERR-7	Недоступность СУБД	HTTP 503	«Сервис временно недоступен»	DB_UNAVAILABLE
ERR-8	Внутренняя ошибка PHP	HTTP 500, без стек-трейса	«Внутренняя ошибка, обратитесь к администратору»	INTERNAL_ERROR

Таблица 5. Варианты обработки ошибок



Российский государственный университет нефти и газа (НИУ) имени И.М. Губкина
ФАКУЛЬТЕТ КОМПЛЕКСНОЙ БЕЗОПАСНОСТИ ТЭК

№	Категория	Формулировка	Источник
NFR-1	Безопасность	Противодействие XSS и CSRF на всех этапах взаимодействия	[OWASP Top 10 — 2021]
NFR-2	Безопасность	Cookie с атрибутами HttpOnly, Secure, SameSite	[OWASP Session Management Cheat Sheet]
NFR-3	Безопасность	Безопасные HTTP-заголовки (X-Content-Type-Options, X-Frame-Options, HSTS, Referrer-Policy, CSP)	[OWASP Secure Headers Project]
NFR-4	Надёжность	Доступность при штатной нагрузке $\geq 99,5$ % расчётного времени работы	[ГОСТ Р 53480-2009]; [ГОСТ Р ИСО/МЭК 25010-2015]
NFR-5	Производительность	Время отклика ≤ 2 с для 95 % операций при штатной нагрузке	[Miller R. B., 1968 («Doherty threshold»)]; [ГОСТ Р ИСО 9241-110-2009]
NFR-6	Масштабируемость	Компоненты в изолированных контейнерах, допускают горизонтальное масштабирование	[Newman S. Building Microservices, 2-е изд., 2021]
NFR-7	Переносимость	Развёртывание в облаке без модификации кода	[ГОСТ Р ИСО/МЭК 25010-2015]
NFR-8	Наблюдаемость	Логирование событий с IP, временем, страницей, действием	[ГОСТ Р ИСО/МЭК 27002-2021]
NFR-9	Восстанавливаемость	Резервное копирование журналов с настраиваемой периодичностью	[ГОСТ Р ИСО/МЭК 27002-2021]

Таблица 5. Нефункциональные требования



ID	Сценарий	Актор	Краткое описание
UC-001	Открытие стартовой страницы	A-1	Доступ к форме входа и регистрации
UC-002	Регистрация пользователя	A-1	Создание учётной записи
UC-003	Авторизация пользователя	A-1 → A-2	Вход по логину и паролю
UC-004	Просмотр профиля	A-2	Просмотр персональных данных
UC-005	Защита от XSS-атаки	A-4 → Система	Блокировка XSS-вектора во входных данных
UC-006	Защита от CSRF-атаки	A-4 → Система	Отклонение запроса без CSRF-токена
UC-007	Журналирование и поведенческий анализ	A-5 → Система	Фиксация событий, блокировка аномального поведения
UC-008	Просмотр панели инцидентов	A-3	Просмотр и фильтрация журнала событий

Таблица 6. Сценарии использования



Этап	Описание	Угроза по БДУ ФСТЭК	Источник угрозы
1	Открытие стартовой страницы	УБИ.030 (использование данных по умолчанию)	Перехват трафика, открытый доступ
2	Передача данных в БД при регистрации/авторизации	УБИ.033 (слабости кодирования), УБИ.041 (XSS)	Невалидированные данные пользователя
3	Действия в профиле	УБИ.042 (CSRF), УБИ.017 (доступ к cookies)	Запросы с внешних ресурсов, перехват cookie

Таблица 7 – Применимые угрозы по этапам пользовательского сценария

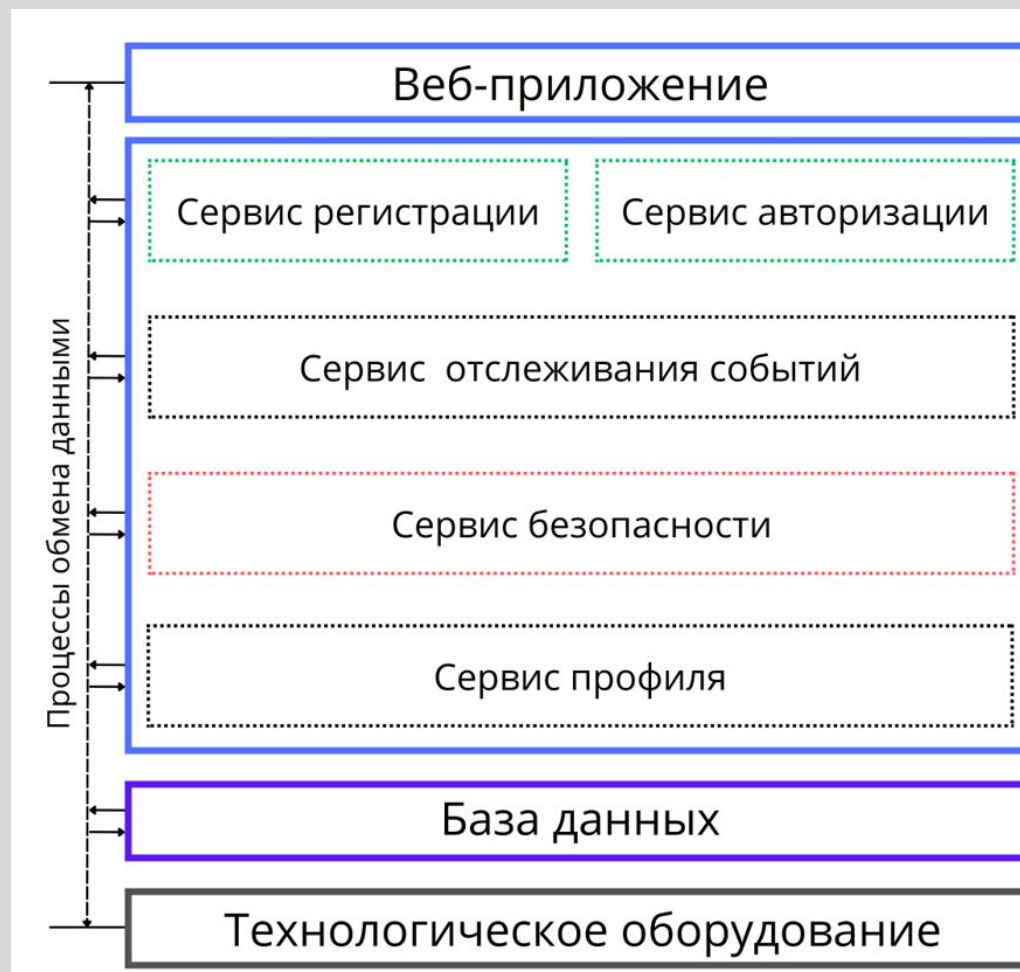


Рисунок 2 – Модель веб-приложения на основе микросервисов с



Рисунок 3 – Архитектура подсистемы регистрации



Рисунок 4 – Архитектура подсистемы авторизации

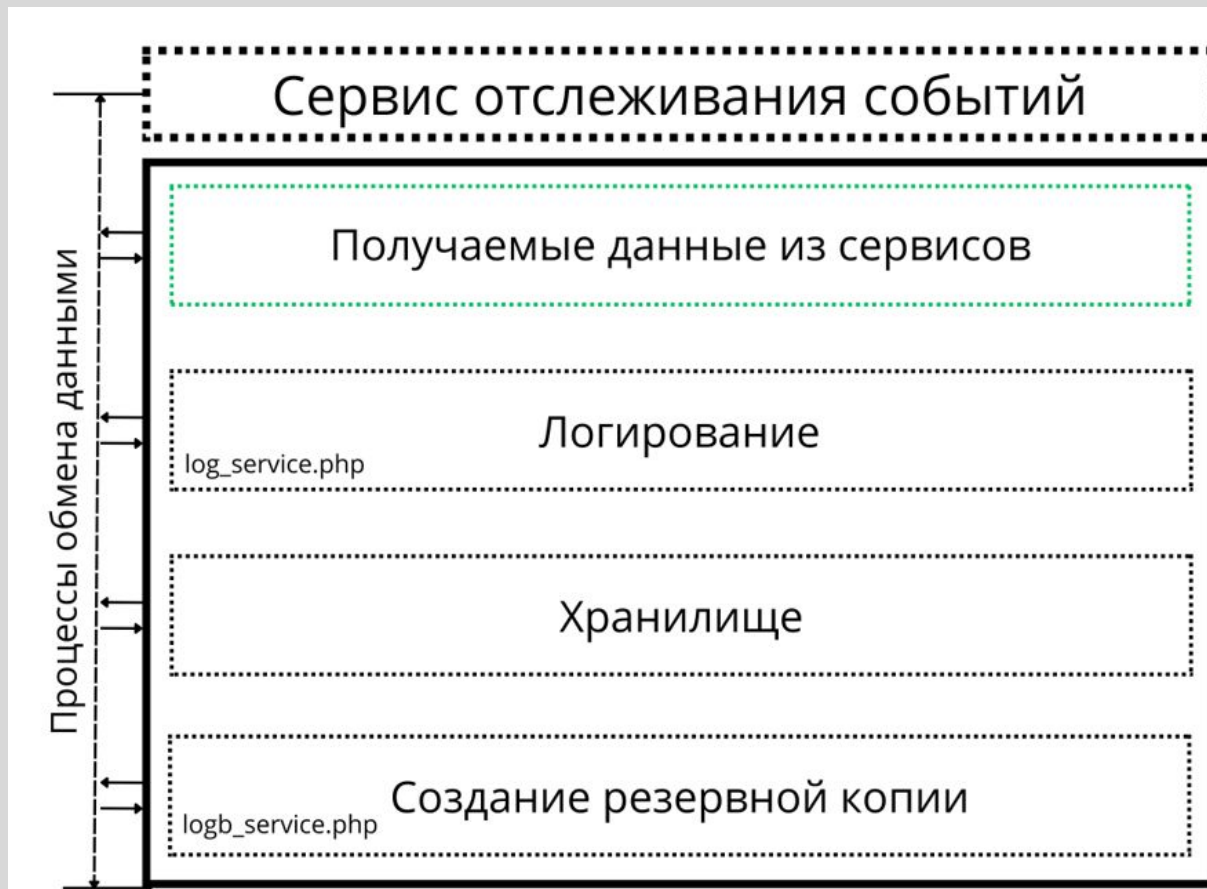


Рисунок 5 – Архитектура подсистемы отслеживания событий



Рисунок 6 – Архитектура сервиса безопасности

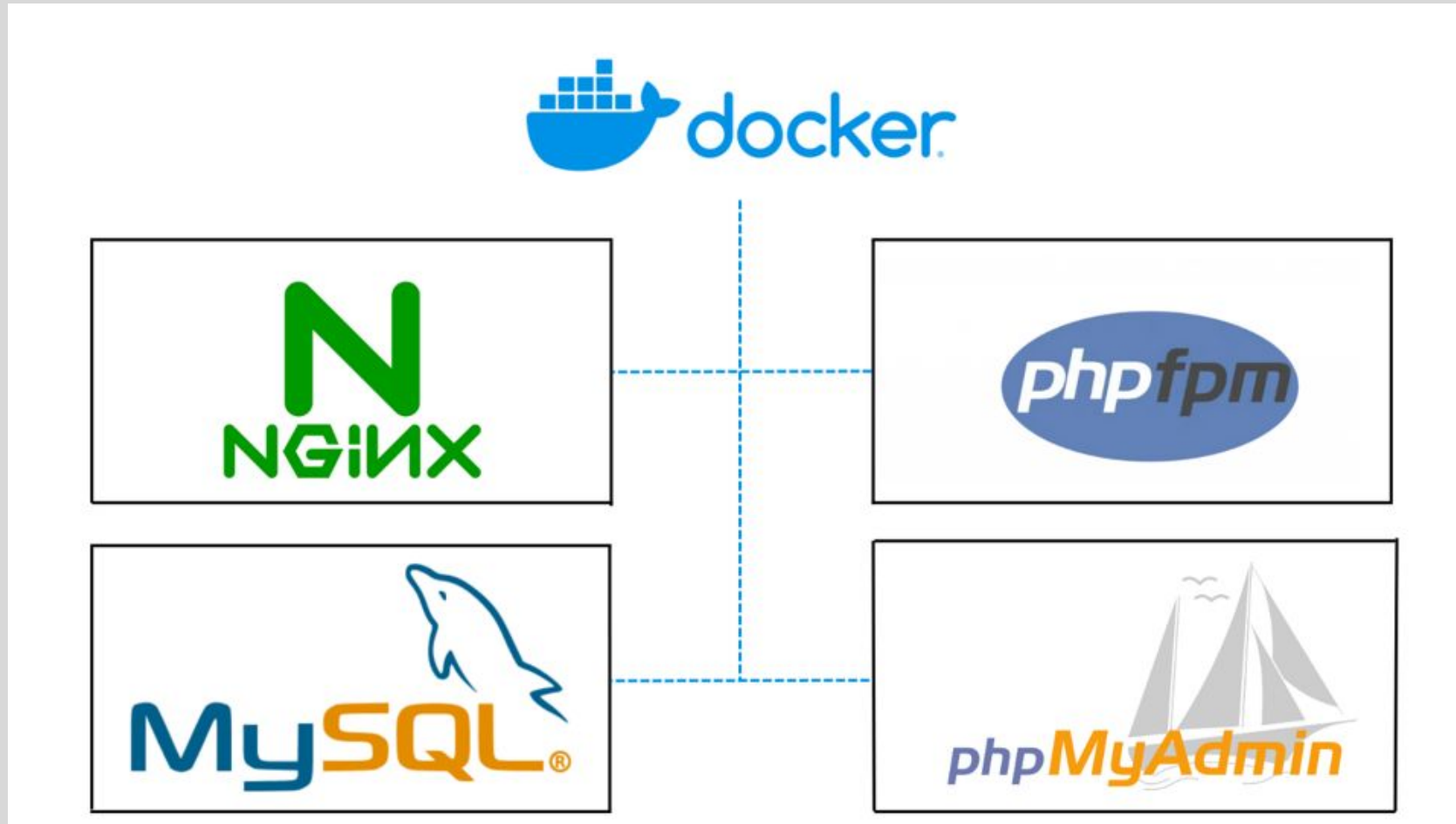


Рисунок 7 – Используемый стек-технологий



Российский государственный университет нефти и газа (НИУ) имени И.М. Губкина

ФАКУЛЬТЕТ КОМПЛЕКСНОЙ БЕЗОПАСНОСТИ ТЭК



Рисунок 8 – Структура проекта

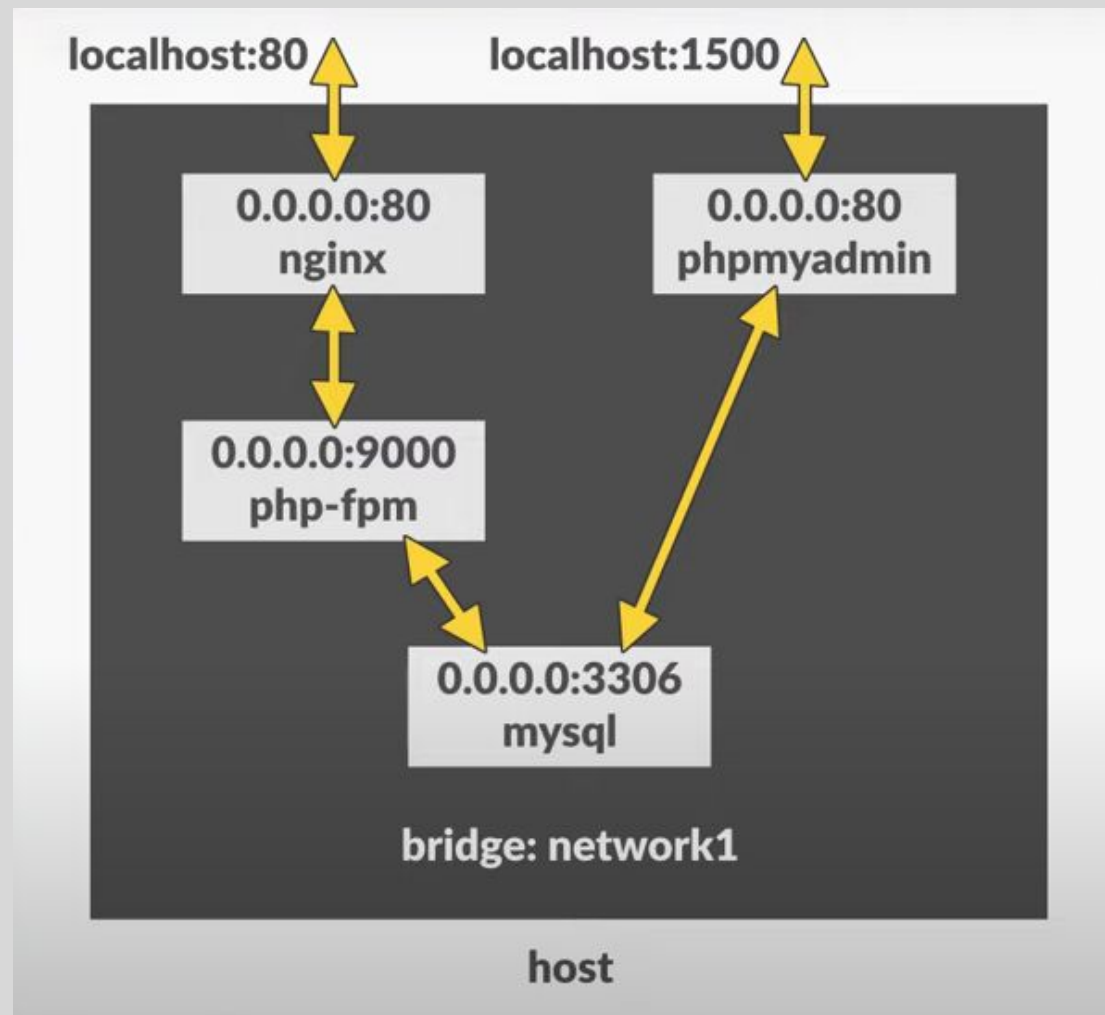


Рисунок 9 – Схема взаимодействия контейнеров



Выполнил ВКР
Лазорин Д.С.
группа КС-21-04

Исходный код

Рады вас видеть

Пройдите регистрацию

ФИО

Email

Пароль

Повтор пароля

Зарегистрироваться

У вас есть аккаунта? [Войти](#)

Рисунок 10 – Форма регистрации

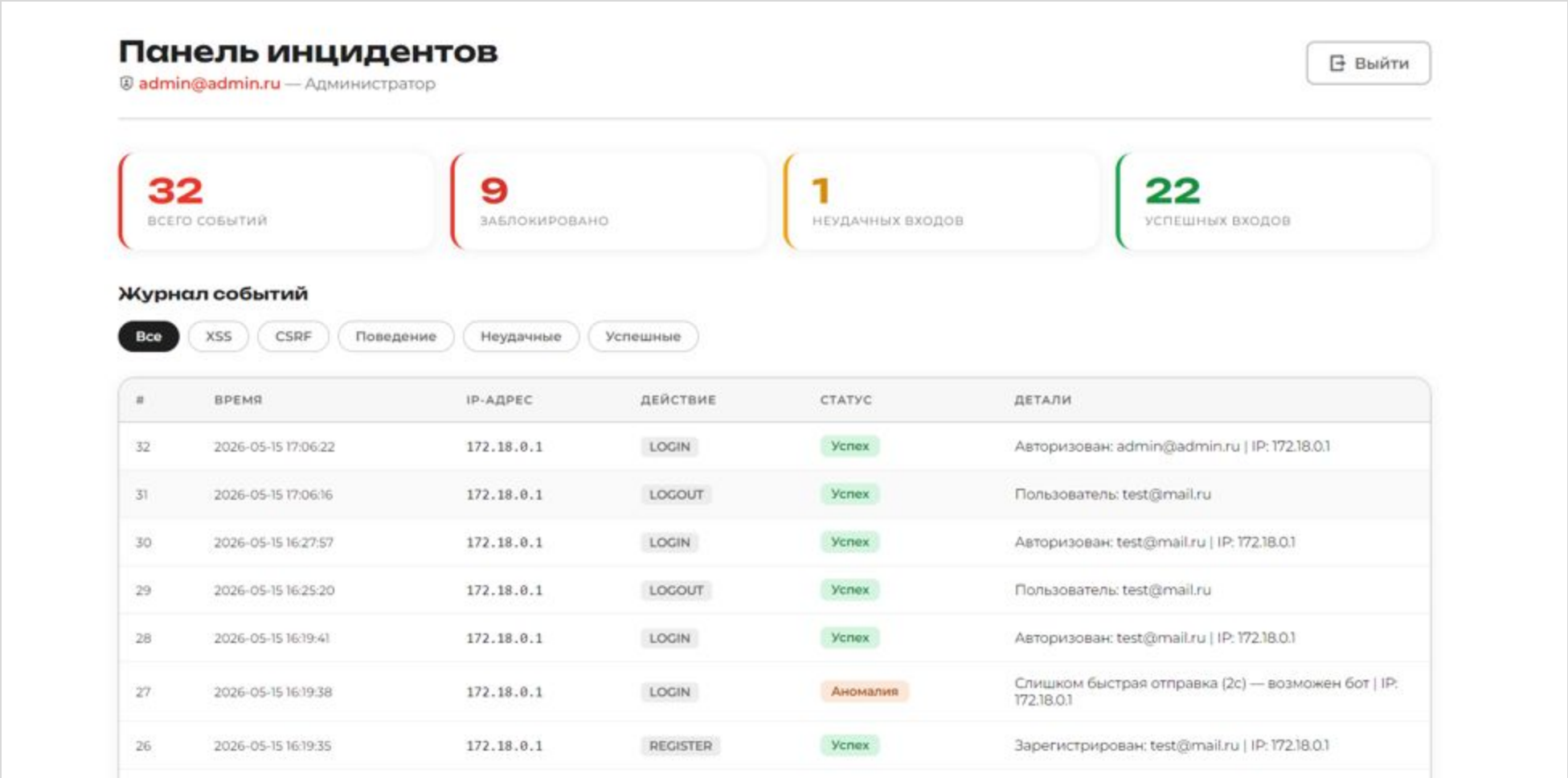


Рисунок 11 – Страница панели инцидентов администратора

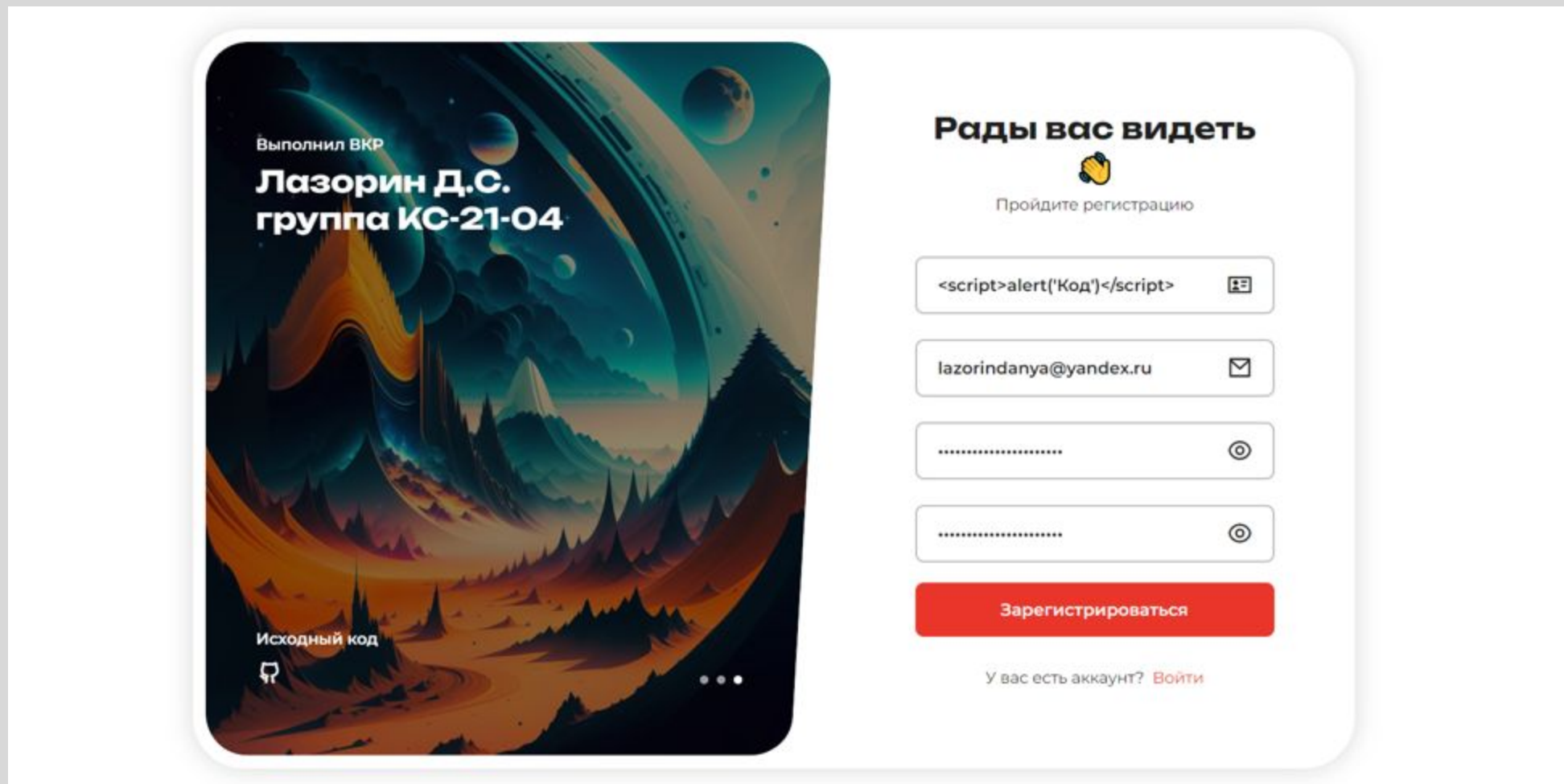


Рисунок 12 – Проведение XSS атаки



42	2026-05-19 07:48:59	172.18.0.1	REGISTER	XSS	XSS-паттерн в поле: name IP: 172.18.0.1
----	---------------------	------------	----------	-----	---

Рисунок 13 – Блокирование XSS-атаки на этапе ввода данных



Заключение

В ходе выполнения научно-исследовательской работы была решена задача разработки паттерна для обеспечения безопасности группы веб-ресурсов в нефтегазовом комплексе. В соответствии с поставленной целью были выполнены все необходимые задачи.